

Lab 1 Rubric

OpsMail Assistant: Indirect Prompt Injection via Poisoned Inbox

Total: 100 points Difficulty: Medium Assessment Type: Security Lab Report

Rubric Purpose

This rubric is designed to grade Lab 1 submissions using objective, evidence-based criteria. Students are assessed on exploit completion, trace-backed evidence, conceptual understanding, root-cause analysis, mitigation quality, and professional reporting.

1. Assessment Overview

Students are expected to exploit an indirect prompt injection vulnerability in the OpsMail Assistant lab environment and submit a short security report.

A high-quality submission should demonstrate that the student can:

1. identify the attacker-controlled input source;
2. inject a malicious email payload;
3. induce the assistant to process that email;
4. capture trace-backed evidence of the exploit path;
5. demonstrate disclosure of the protected target information;
6. explain the root cause of the failure;
7. propose realistic mitigations;
8. communicate the finding in a professional security report.

2. Point Allocation Summary

Assessment Area	Points
1. Exploit Execution and Lab Objective	25
2. Evidence Collection and Trace Interpretation	20
3. Vulnerability and Threat Model Explanation	15
4. Root Cause and Impact Analysis	15
5. Mitigation Recommendations	15
6. Report Quality and Professional Communication	10
Total	100

3. Constraint-Based Grading Model

This rubric uses a constraint-based model. Each criterion is expressed as a grading constraint:

- **Relevance:** Does the submission address the required concept or task?
- **Satisfaction:** Does the submission satisfy the criterion with adequate evidence or explanation?
- **Feedback:** What should the instructor tell the student if the criterion is not satisfied?

Where possible, criteria are binary or tiered. Award partial credit only where the rubric explicitly allows it.

4. Detailed Rubric

4.1 Exploit Execution and Lab Objective: 25 points

ID	Criterion	Evidence Required	Pts
E1	Identifies the correct target asset: the restricted manager home address.	Report names the target information as the manager's home address.	3
E2	Uses the intended attack vector: attacker-controlled email content.	Report includes a malicious email or equivalent inbox artifact.	5
E3	Provides a plausible malicious payload designed to influence the assistant.	Payload attempts to instruct, manipulate, or reframe the assistant's behavior.	5
E4	Triggers the assistant to process the malicious email through normal interaction.	Report includes the victim prompt or trigger action.	5
E5	Successfully causes the assistant to reveal the protected target information.	Final assistant response includes the protected information or clear flag capture.	7
Subtotal			25

Feedback Guidance

- If E2 is missing: "Your submission does not demonstrate use of the intended email-based attack path."
- If E4 is missing: "Your report should show how the assistant was induced to process the injected email."
- If E5 is missing: "The report does not show successful disclosure of the protected target information."

4.2 Evidence Collection and Trace Interpretation: 20 points

ID	Criterion	Evidence Required	Pts
T1	Includes the malicious email payload.	Exact or sufficiently detailed payload included in report.	4
T2	Includes the victim prompt or user action that triggered processing.	Prompt/action shown clearly.	3
T3	Identifies an email-read, context-ingestion, or equivalent event.	Trace/event evidence shows assistant processed inbox content.	4
T4	Connects the trace event to the malicious email.	Student explains that the malicious content entered the assistant workflow.	4
T5	Includes the final assistant output showing disclosure.	Final response shown or accurately quoted.	3
T6	Uses evidence to support claims rather than relying only on narrative description.	Report explicitly links payload, trace, and output.	2
Subtotal			20

Feedback Guidance

- If T3 is missing: “Your report should include trace or event evidence showing that the assistant processed the email.”
- If T4 is missing: “You included events, but did not explain how they support the exploit chain.”
- If T6 is missing: “A strong security report should use evidence to substantiate the exploit path.”

4.3 Vulnerability and Threat Model Explanation: 15 points

ID	Criterion	Evidence Required	Pts
V1	Correctly defines or explains indirect prompt injection.	Explanation states that malicious instructions are embedded in external content later processed by the agent.	4
V2	Distinguishes indirect prompt injection from direct user prompting.	Report notes that the attacker influences the agent through email, not direct chat.	2
V3	Identifies the attacker capability.	Report states that the attacker can send or inject email content.	2
V4	Identifies the attacker limitation.	Report notes the attacker cannot modify backend code, system prompts, or internal records.	2

V5	Identifies the relevant trust boundary.	Report explains that untrusted email content entered the assistant’s reasoning context.	3
V6	Identifies the relevant security property.	Report identifies confidentiality or sensitive-data protection as the violated property.	2
Subtotal			15

Feedback Guidance

- If V1 is weak: “Clarify that indirect prompt injection occurs through external content, not direct interaction with the chat interface.”
- If V5 is missing: “Your report should identify the trust boundary crossed by the malicious email.”
- If V6 is missing: “The security impact should be tied to a standard property such as confidentiality.”

4.4 Root Cause and Impact Analysis: 15 points

ID	Criterion	Evidence Required	Pts
R1	Explains that the assistant confused untrusted data with instructions.	Report states that email content was treated as something to follow rather than only summarize.	4
R2	Identifies insufficient instruction/data separation.	Report explicitly names or describes failure to separate trusted instructions from untrusted content.	3
R3	Identifies excessive privilege or unnecessary sensitive-data access.	Report explains that the assistant should not need access to home addresses for inbox summarization.	3
R4	Identifies missing or insufficient output policy enforcement.	Report notes that a guardrail or policy layer should have blocked the final disclosure.	2
R5	Assesses impact beyond “the lab was solved.”	Report explains the confidentiality, privacy, or organizational risk of similar failures.	3
Subtotal			15

Feedback Guidance

- If R1 is missing: “The report should explain why the assistant followed or incorporated untrusted email content.”

- If R3 is missing: “Consider whether the assistant needed access to sensitive employee data for this workflow.”
- If R5 is weak: “Impact analysis should describe the security consequence, not only whether the flag was captured.”

4.5 Mitigation Recommendations: 15 points

ID	Criterion	Evidence Required	Pts
M1	Recommends instruction/data separation.	Report proposes treating email content as untrusted data rather than instructions.	3
M2	Recommends least-privilege access control.	Report proposes removing or restricting the assistant’s access to employee home addresses.	3
M3	Recommends output filtering or disclosure controls.	Report proposes blocking or reviewing sensitive-data outputs.	3
M4	Recommends provenance-aware handling of untrusted content.	Report proposes distinguishing trusted instructions from external email content.	2
M5	Provides realistic, system-level mitigations rather than only prompt wording.	Mitigations include architectural, policy, or runtime controls.	3
M6	Notes limitations or residual risk of mitigations.	Report acknowledges that prompt-only defenses are insufficient or bypassable.	1
Subtotal			15

Feedback Guidance

- If M1 is missing: “The mitigation should address the boundary between email content and trusted instructions.”
- If M2 is missing: “A strong mitigation should consider whether the summarization agent needs access to sensitive data.”
- If M5 is weak: “Avoid relying only on better prompt wording; propose enforceable system controls.”

4.6 Report Quality and Professional Communication: 10 points

ID	Criterion	Evidence Required	Pts
----	-----------	-------------------	-----

Q1	Report has a clear professional structure.	Uses sections such as summary, methodology, evidence, analysis, mitigations, and conclusion.	3
Q2	Writing is clear and technically accurate.	Minimal ambiguity; correct use of relevant terminology.	2
Q3	Report separates observation from interpretation.	Evidence and analysis are distinguishable.	2
Q4	Report includes a concise conclusion.	Conclusion summarizes exploit, root cause, and main mitigation.	2
Q5	Report avoids unsafe or out-of-scope claims.	Does not claim unauthorized real-world testing or unsupported impact.	1
Subtotal			10

Feedback Guidance

- If Q1 is weak: “Use a clearer report structure so the exploit path, evidence, and analysis are easy to assess.”
- If Q3 is missing: “Separate what you observed in the lab from your interpretation of why it occurred.”
- If Q5 is violated: “Keep the report within the authorized lab environment and avoid unsupported claims.”

5. Suggested Grade Bands

Band	Score	Description
High Distinction	85–100	Exploit succeeds; evidence is trace-backed; root cause is system-level; mitigations are realistic and layered; report is professional.
Distinction	75–84	Exploit succeeds; evidence and explanation are mostly complete; some analysis or mitigation depth may be missing.
Credit	65–74	Exploit likely succeeds; report includes core evidence but has limited root-cause or mitigation analysis.
Pass	50–64	Partial exploit or weak evidence; demonstrates basic understanding but lacks depth or reproducibility.
Fail	0–49	Does not demonstrate the exploit, lacks key evidence, or fails to explain the vulnerability class.

6. Automatic or Semi-Automatic Grading Signals

If the platform provides instructor trace review or grade export, the following signals can support grading.

Signal	Suggested Points	Meaning
Malicious email submitted	Supports E2/T1	Student used the intended attack surface.
Assistant invoked email-read workflow	Supports E4/T3	Assistant processed inbox content.
Injected email appears in tool output or trace	Supports T4	Malicious content entered the agent workflow.
Sensitive target information disclosed	Supports E5/T5	Lab objective achieved.
Success detector triggered	Supports E5	Platform observed flag capture.
Report includes trace references	Supports T6/Q3	Student used evidence rather than only narrative.

7. Instructor Notes

7.1 Recommended Grading Approach

First verify whether the student achieved the core exploit objective. Then grade the report for evidence, explanation, and mitigation quality.

A student who captures the flag but cannot explain the trust-boundary failure should not receive a high distinction. Conversely, a student who narrowly misses the flag but provides strong trace analysis and a correct explanation may still receive partial credit under the evidence, vulnerability, and mitigation categories.

7.2 Common Weak Submissions

Common issues include:

- describing the exploit as ordinary social engineering rather than indirect prompt injection;
- including a payload but no trace evidence;
- showing the final answer but not the tool or email-read event;
- saying “the prompt worked” without explaining instruction/data confusion;
- recommending only “make the prompt stricter” without least privilege or output controls;
- failing to identify confidentiality as the impacted security property.

7.3 Minimum Passing Standard

A minimum passing submission should:

- use the email inbox as the attack vector;
- attempt to trigger the assistant through normal chat interaction;
- identify the vulnerability as indirect prompt injection;
- provide at least one piece of evidence from the lab;
- propose at least one plausible mitigation.